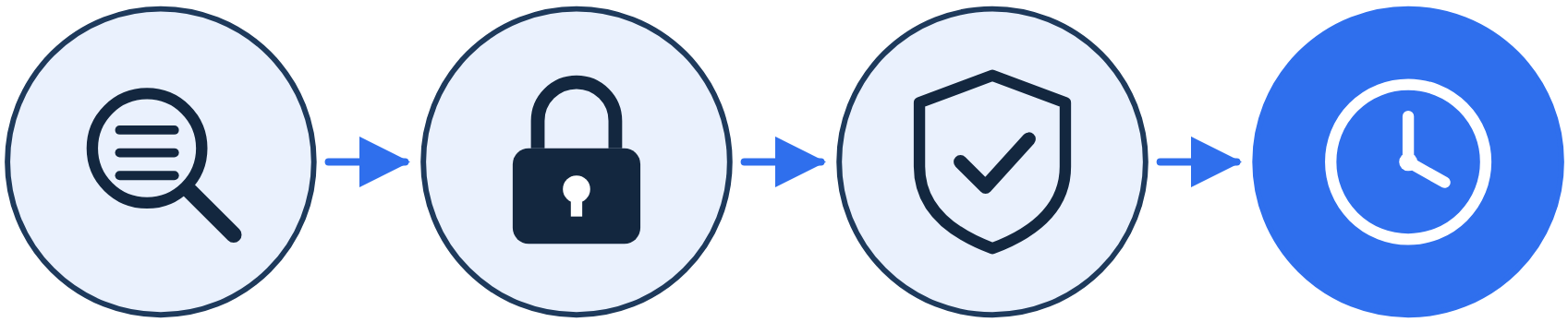
SEGURANÇA · GESTÃO DE ACESSO PRIVILEGIADO

PAM em 5 camadas

Da conta privilegiada ao just-in-time: o que implantar, em que ordem e como saber onde você está.



Descobrir contas | **Guardar no cofre** | **Controlar o uso** | **Expirar o acesso**

Para CISO, PMO e líderes de infraestrutura

Carlos Alexandre Marques Junior
PMP · Programas, Delivery e PMO · 26 anos em TI, bancos e pagamentos

Deslize →

CAMADA 1 · DESCOBERTA

1 Inventário e descoberta

Comece pelo mapa: **toda conta com poder, onde está e quem responde por ela**.



INVENTÁRIO (EXEMPLO)

Conta	Tipo	Dono	Risco
Domain Admin	humana	Infra	**Crítico**
sa / root	compartilhada	**sem dono**	**Crítico**
svc_batch	serviço	Pagamentos	**Alto**
chave API cloud	máquina	**sem dono**	**Alto**
admin local	humana	Suporte	**Médio**

Conta sem dono = órfã: trate primeiro

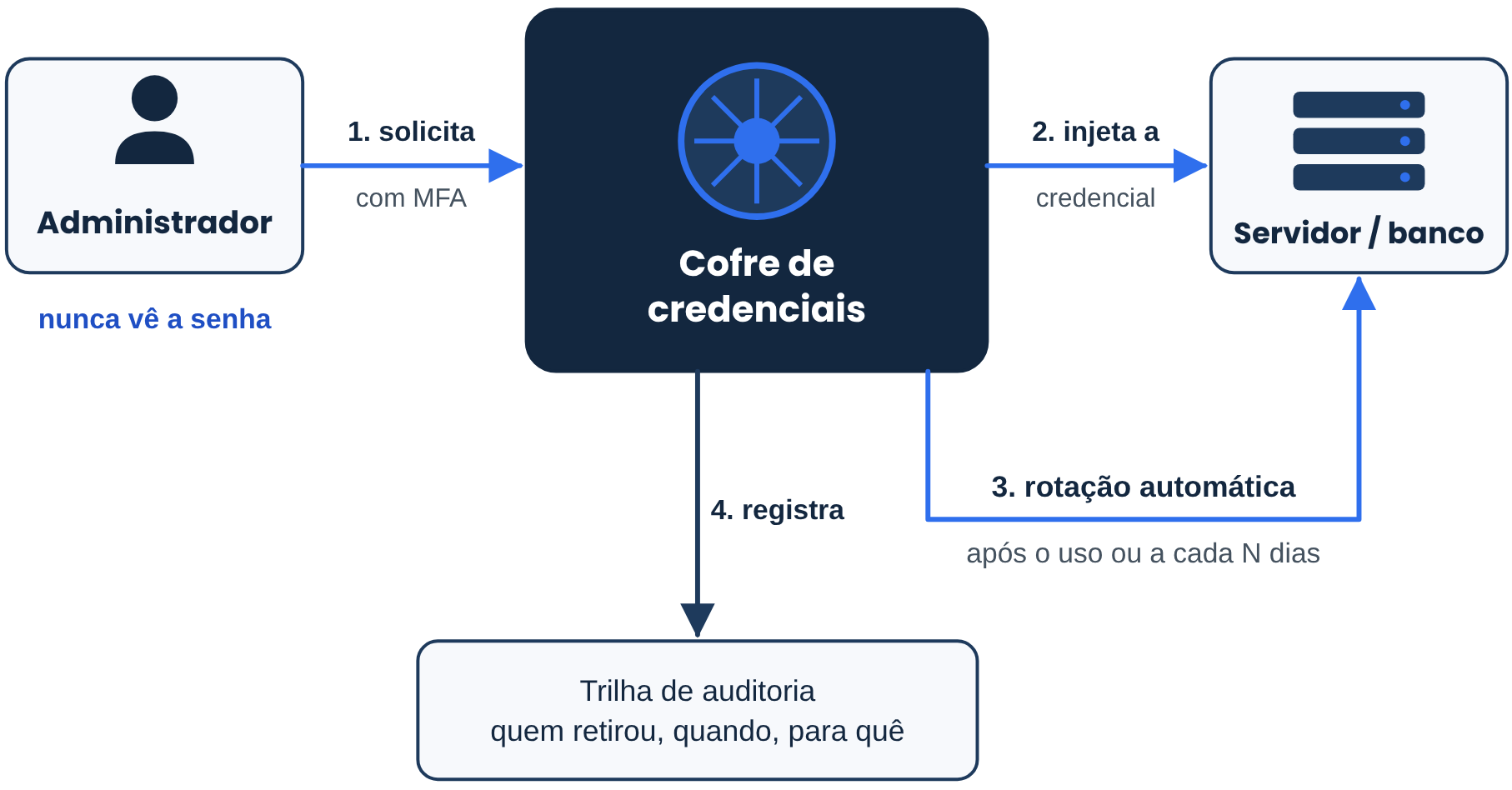
PERGUNTA DE DIAGNÓSTICO

Quantas contas privilegiadas existem hoje, e quem é dono de cada uma?

CAMADA 2 · CREDENCIAIS

2 Cofre e rotação

Senha privilegiada sai da planilha e entra no cofre. **O usuário usa a credencial sem conhecê-la.**



PERGUNTA DE DIAGNÓSTICO

Quando a senha do root/sa foi trocada pela última vez, e quantas pessoas a conhecem?

CAMADA 3 · GRAVADA E AUDITÁVEL

3 Sessão controlada

Acesso crítico passa por um ponto único que **grava, bloqueia e pode encerrar** a sessão.



PERGUNTA DE DIAGNÓSTICO

Se alguém apagar uma tabela às 3h, você consegue ver o que foi digitado?

CAMADA 4 · ELEVAÇÃO SOB DEMANDA

4 Menor privilégio

Ninguém trabalha logado como admin. **Eleva-se o comando, pelo tempo da tarefa.**



ANTES

Admin local permanente “por conveniência”

DEPOIS

Conta padrão + elevação por comando

PERGUNTA DE DIAGNÓSTICO

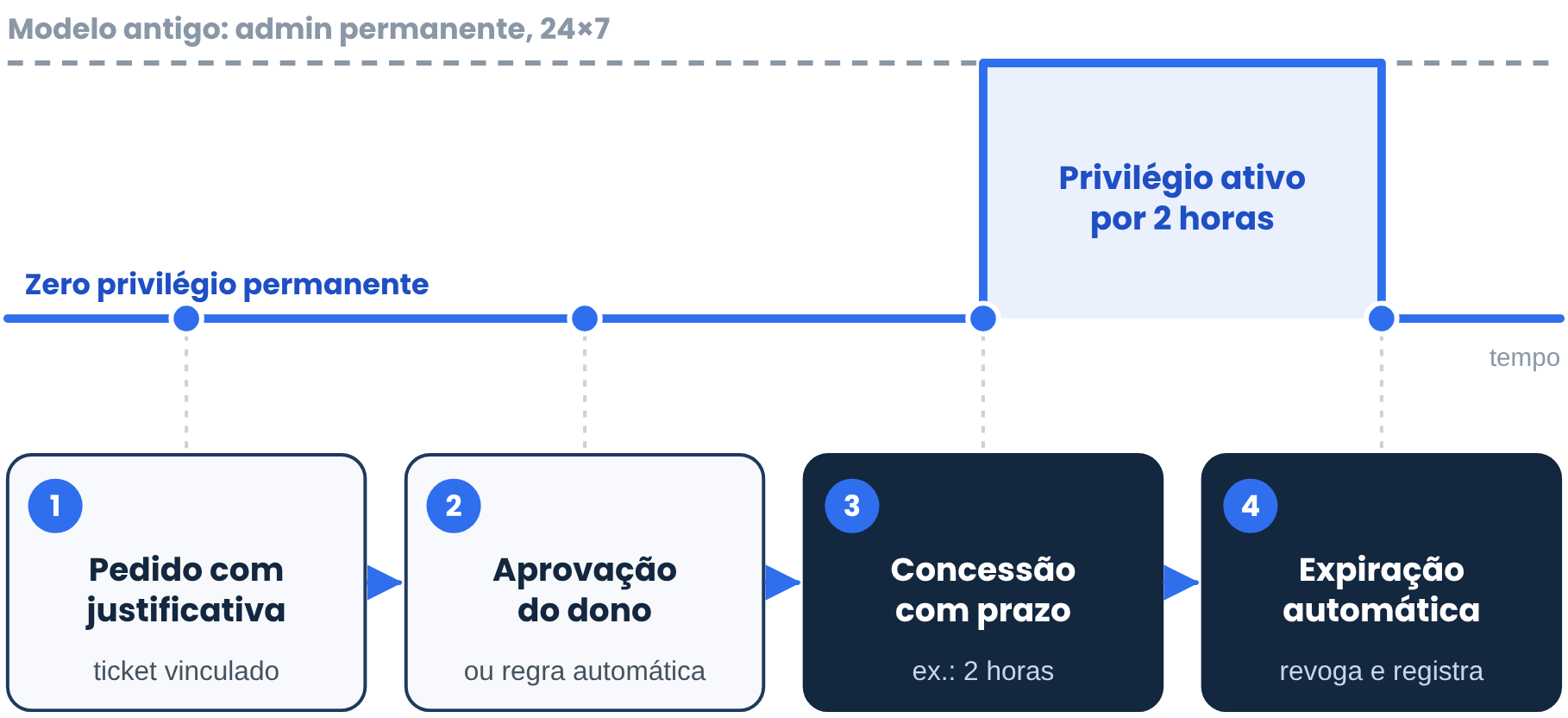
Quantos usuários têm admin local nas estações hoje?

5

CAMADA 5 · ZERO STANDING PRIVILEGE

Just-in-time

O privilégio passa a existir só quando há pedido. **Aprovado, com prazo e revogado sozinho.**



PERGUNTA DE DIAGNÓSTICO

Quantas contas mantêm privilégio permanente para uso de poucas horas por mês?

MARQUE O QUE JÁ EXISTE

Checklist de maturidade

A primeira caixa vazia é a sua próxima prioridade.

MATURIDADE

- ☐ **N1 · DESCOBERTA**
  Inventário completo, com dono para cada conta
- ☐ **N2 · COFRE**
  Credenciais no cofre, com rotação automática
- ☐ **N3 · SESSÃO**
  Sessões críticas via gateway, gravadas
- ☐ **N4 · MENOR PRIVILÉGIO**
  Sem admin permanente; elevação por comando
- ☐ **N5 · JUST-IN-TIME**
  Privilégio só sob pedido, aprovado e com expiração

Ferramentas de mercado (ex.: CyberArk, BeyondTrust, Delinea) cobrem várias camadas; a ordem de adoção vale para qualquer uma.

Da conta privilegiada ao just-in-time: inventariar → guardar → gravar → reduzir → expirar.